

OT Security Incident Report

Incident: Unauthorized Modbus Command Injection Against a Programmable Logic Controller (PLC)

Environment: Virtualized ICS/OT Security Lab

Framework: PICERL (Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned)

Classification: Manipulation of Control (unauthorized writing to a control output)

Executive Summary

An unauthorized Modbus Write Single Coil command (function code 5) was detected against a PLC controlling a simulated pump, forcing a control output to change state with no authentication and no corresponding operator action. The event was identified through live network traffic analysis, contained via a firewall rule blocking the affected port, and used to derive preventive controls. This report documents the incident end-to-end using the PICERL incident-response lifecycle.

The incident demonstrates a fundamental limitation of legacy OT protocols: Modbus provides no authentication or encryption, so any host able to reach the PLC can both read and alter physical process state. The defensive conclusion is that such protocols must be protected by network segmentation, allow-listing, and continuous monitoring rather than by the protocol itself.

Environment Overview

Component	Role	Detail
PLC (simulated)	Control device	Modbus TCP server, port 502; Coil 0 = Pump, Register 0 = Tank Level
HMI / Dashboard	Operator view	Polls the PLC every second (read-only)
Attacker	Threat actor	Issues an unauthorized write to the PLC
Wireshark	Monitoring	Live packet capture of Modbus traffic

Priority model applied: OT prioritizes Safety → Availability → Integrity → Confidentiality. Response decisions favored maintaining a safe, available process over other concerns.

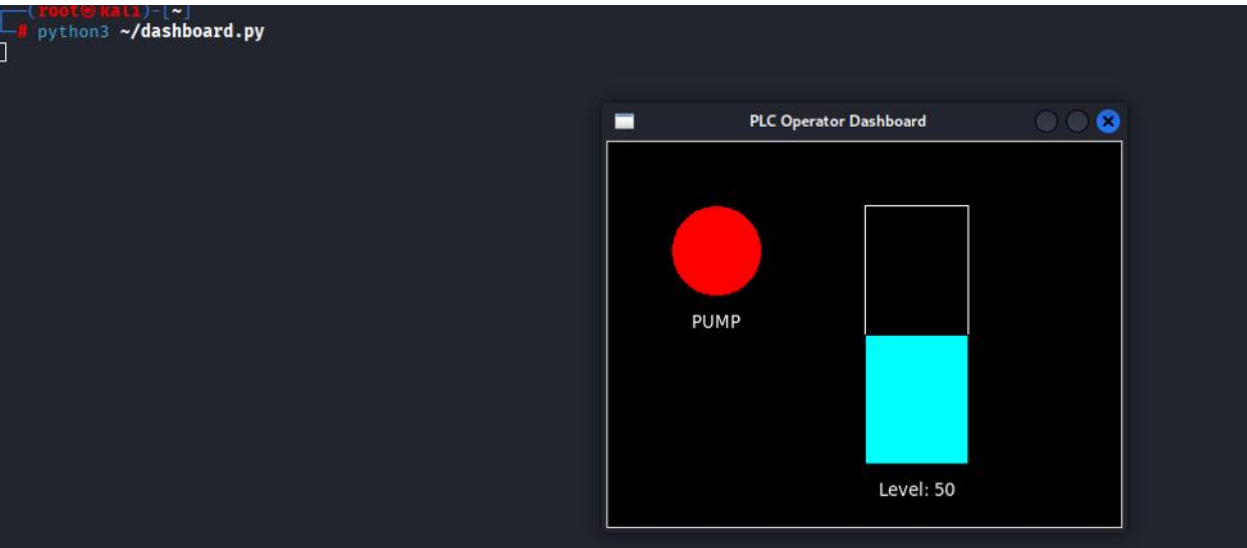


Figure1: Operator dashboard showing normal pump state (OFF)

PICERL Lifecycle

P — Preparation

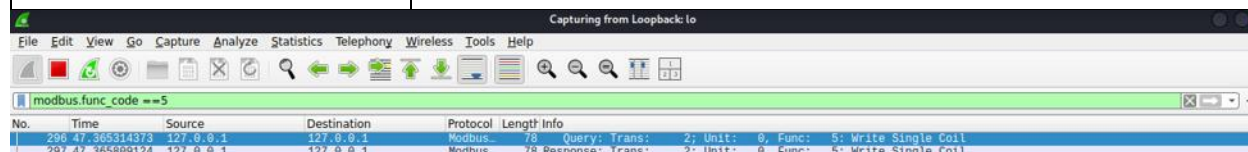
Prior to the incident, the environment had continuous network monitoring in place (Wireshark capturing Modbus traffic), and a known baseline of normal activity was established: the HMI polling the PLC using read function codes (1 = Read Coils, 3 = Read Holding Registers) at a steady one-second cadence. This baseline is what made the subsequent anomaly detectable.

I — Identification

At 16:24:55.764, monitoring identified an anomalous **Write Single Coil command (Modbus function code 5)** among the otherwise read-only traffic. The write targeted pump control and changed its state with no authenticating credentials and no operator action.

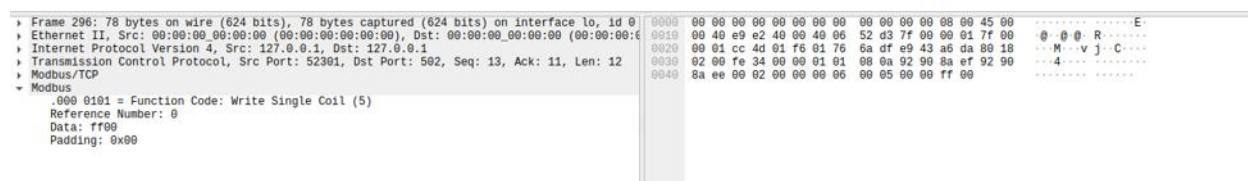
Indicators of Compromise (IOC):

Attribute	Value
Timestamp	2026-08-11 06:00:57
Function code	5 (Write Single Coil) anomalous vs. baseline codes 1 and 3
Reference number	0 (Coil 0 = Pump)
Value written	FF 00 (ON / True)
Source	127.0.0.1 (attacker)
Destination	127.0.0.1:502 (PLC)
Occurrences	2 unauthorized write commands observed



The image shows a Wireshark packet capture window titled "Capturing from Loopback: lo". The filter is set to "modbus.func_code == 5". The packet list shows two packets: a query (No. 296) and a response (No. 297). The packet details pane shows the Modbus protocol structure: Query (Trans: 2, Unit: 0, Func: 5, Write Single Coil) and Response (Trans: 2, Unit: 0, Func: 5, Write Single Coil).

No.	Time	Source	Destination	Protocol	Length	Info
296	47.65514373	127.0.0.1	127.0.0.1	Modbus	78	Query: Trans: 2; Unit: 0; Func: 5: Write Single Coil
297	47.365899124	127.0.0.1	127.0.0.1	Modbus	78	Response: Trans: 2; Unit: 0; Func: 5: Write Single Coil



The image shows the packet details and hex data for the unauthorized write command. The details pane shows the Modbus protocol structure: Function Code: Write Single Coil (5), Reference Number: 0, Data: ff00, Padding: 0x00. The hex data pane shows the raw bytes of the packet.

Frame	Time	Source	Destination	Protocol	Length	Info
296	47.65514373	127.0.0.1	127.0.0.1	Modbus	78	Query: Trans: 2; Unit: 0; Func: 5: Write Single Coil
297	47.365899124	127.0.0.1	127.0.0.1	Modbus	78	Response: Trans: 2; Unit: 0; Func: 5: Write Single Coil

Figure 2: Wireshark capture of unauthorized write single coil(function code).

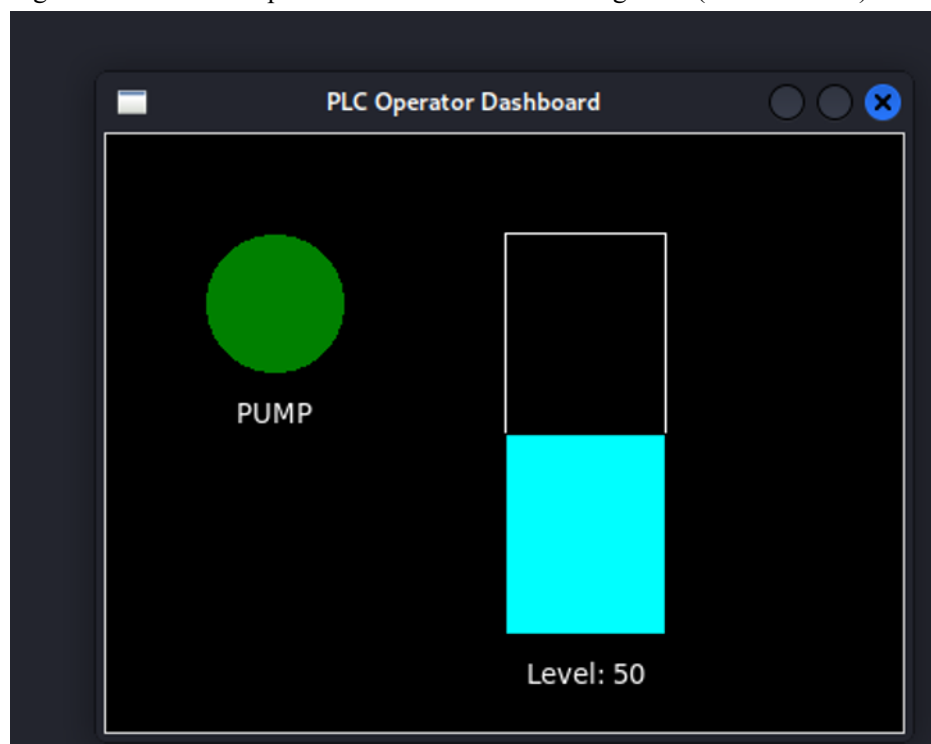


Figure 3: Dashboard showing pump forced ON following the attack

Analysis (normal vs. suspicious): Read function codes (1–4) are expected background activity from the HMI. Write function codes (5, 6, 15, 16) change control state and are rare and deliberate. An unexpected write, with no operator action and no legitimate source context, represents a deviation from baseline and was classified as an incident.

C — Containment

A host firewall rule (iptables) was applied to block inbound traffic to the PLC on port 502 from the attacking source. The attack was re-attempted and failed to connect, confirming containment.

OT nuance observed: Blocking at the port level also disrupted legitimate HMI polling, illustrating the OT trade-off between security and availability. In a production environment, containment would target the attacker's specific source IP so that legitimate operator traffic continues uninterrupted surgical containment rather than a blanket block.

E — Eradication

The attacker's active session was terminated and its source IP permanently blocked (allow-list enforcement). The exploited path unauthenticated write access to the PLC from unauthorized hosts was closed. No malware was involved in this incident; the attack was purely protocol-level command injection, so eradication centered on removing access and closing the exposure rather than removing a malicious file. Had a compromised host been involved, eradication would additionally include malware removal and credential reset.

R — Recovery

Coil 0 (Pump) was restored to its correct authorized state, and normal read-only traffic (function codes 1 and 3) was confirmed to have resumed. Critically, process validation was performed to verify that the physical process was operating correctly and safely before returning to normal operations the OT-specific recovery step that distinguishes restoring a process from merely restoring a system.

L — Lessons Learned

Root cause: The PLC accepted an unauthenticated write command from an unauthorized source a fundamental limitation of legacy Modbus, which has no built-in authentication or encryption.

Preventive controls:

- Network segmentation isolates the OT zone so only authorized systems can reach the PLC (zones and conduits per ISA/IEC 62443).
- Allow-listing permit only the HMI/engineering workstation to communicate with the PLC on port 502; deny all else.
- Continuous monitoring alert on anomalous function codes (writes) and traffic from unauthorized sources, exactly as this incident was detected.
- Compensating controls because the protocol itself cannot authenticate, protection must be enforced externally (segmentation, monitoring, restricted access) rather than at the protocol layer.

Mapping to CompTIA SecOT+ Domains

Activity in this incident	SecOT+ Domain
PLC, Modbus, coils/registers, safety-first model	1.0 OT Systems & Safety
Security vs. availability trade-off in containment	2.0 OT Risk Management
IOC extraction, anomaly vs. baseline	3.0 / 5.0 Threat Intel & Security Ops
Segmentation, allow-listing, zones & conduits	4.0 OT Architecture & Design
Detection via traffic analysis	5.0 OT Security Operations
PICERL response, process validation	6.0 OT Incident Management

Conclusion

This exercise reproduced, detected, contained, and remediated a manipulation-of-control attack against an OT device end-to-end. It demonstrates practical capability across the OT incident-response lifecycle and reinforces the central OT security principle: legacy control protocols cannot secure themselves, so the surrounding architecture segmentation, allow-listing, and monitoring must provide that security.

Prepared as a hands-on OT/ICS security lab exercise. All systems are simulated and isolated; no production environment was involved.